

Защита API

(автоматический поиск уязвимостей)

VTB API 2025[→]
hackathon

SeagullNest (Team293)

Решение полностью работает
и размещено на:

<https://vtb.seag.pro>



Алексей Чайка

Капитан-разработчик

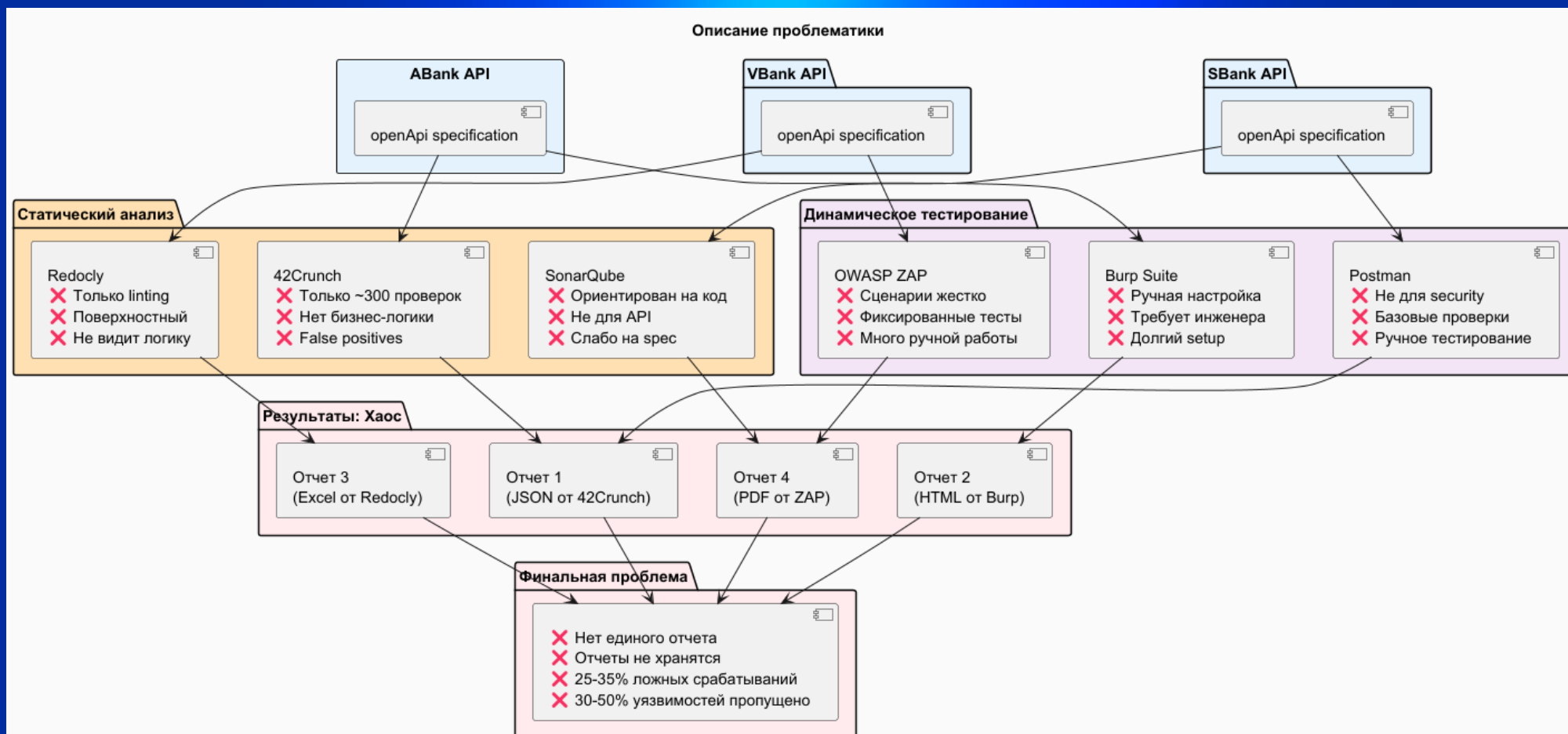
Senior Backend Engineer
ОККО

Проблематика

VTB API 2025[→]
hackathon

Проблемы:

- Каждый банк – новая работа
- 6+ инструментов
- Результаты в разных форматах
- Нет единого представления
- Шум – 25-35% (не представляющие ценности уязвимости)
- Не выявлено уязвимостей: 30-50%



Решение есть!!!

VTB API 2025[→]
hackathon



API Security Analyzer

Автоматический анализ уязвимостей API - VTB Hackathon

- ✓ Статический анализ
- ✓ Динамическое тестирование
- ✓ Валидация контракта
- ✓ AI анализ

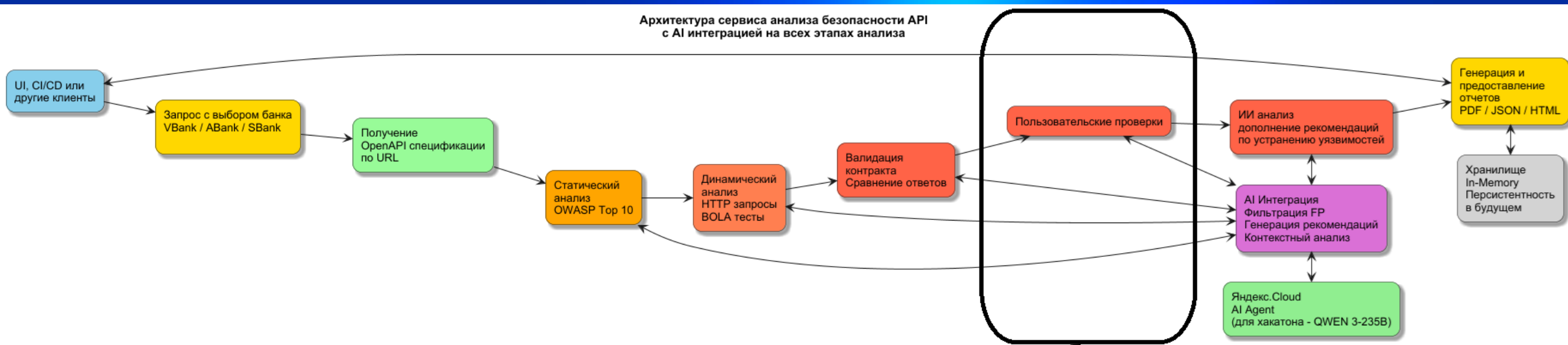


- Расширенный набор всех проверок за раз
- Единый отчет любого формата (pdf/html/json)
- Интеграция с CI/CD процессом (результат – ссылка на отчет)
- Рекомендации по устранению уязвимостей от AI

API Security Analizr

VTB API 2025[→]
hackathon

<https://vtb.seag.pro/>

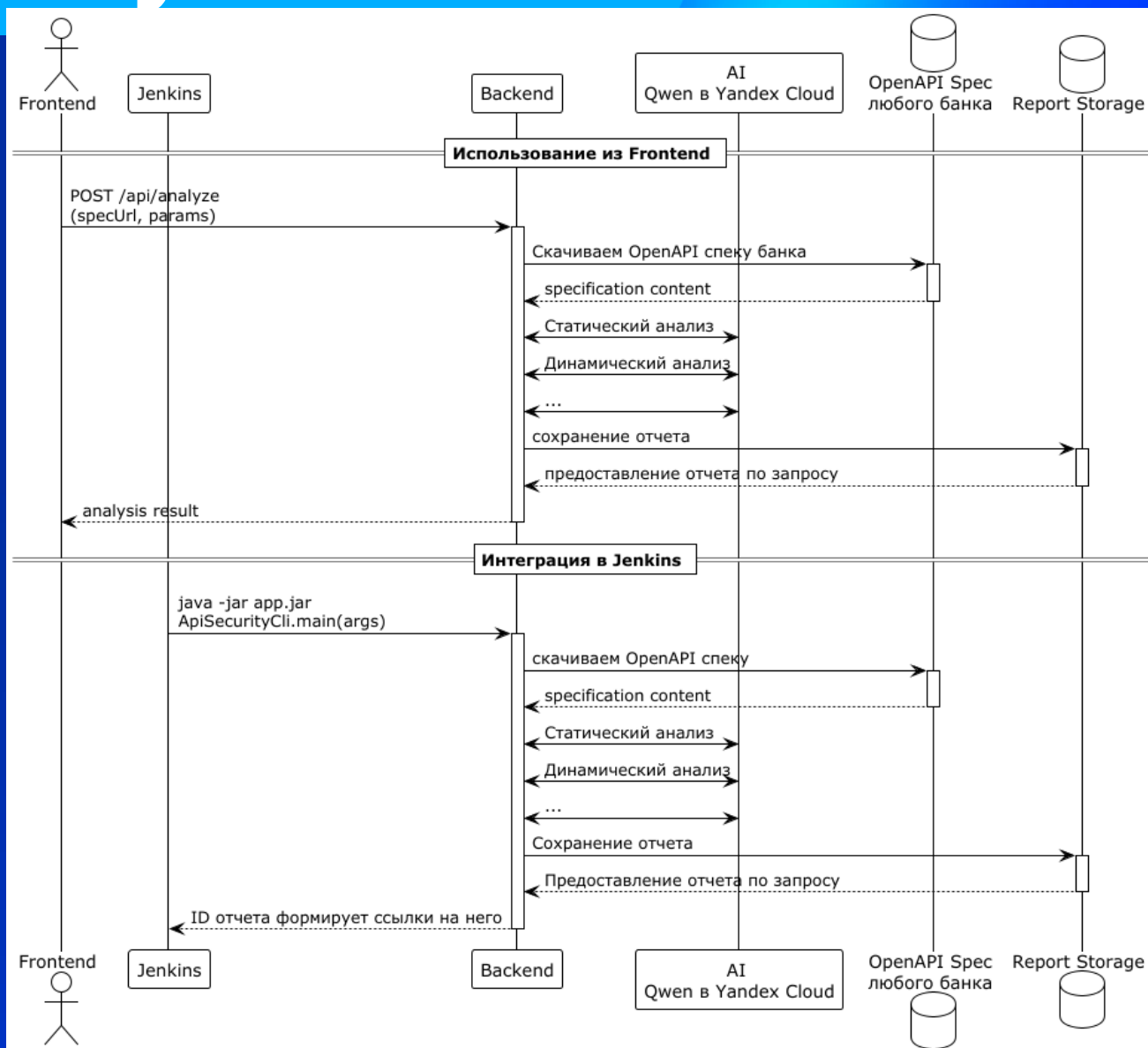


Новый этап (по замечаниям экспертов):
Возможность расширения за счет
пользовательских проверок

API Security Analizr

VTB API 2025
hackathon

<https://vtb.seag.pro/>



Начало работы

VTB API 2025[→]
hackathon

<https://vtb.seag.pro/>

Запустить анализ

Быстрый выбор:

VBank API

ABank API

SBank API

OpenAPI Specification URL:

<https://api.example.com/openapi.json>

API Base URL:

<https://api.example.com>

► Дополнительные настройки



Запустить анализ

1. Выберите банк из списка имеющихся конфигураций

Начало работы

<https://vtb.seag.pro/>

Выберите методы анализа:

- статический анализ спецификации
- динамическое тестирование (на API шлются реальные запросы для поиска уязвимостей)
- Валидация контракта
- AI анализ уязвимостей

Настройки анализа:

- ☒ Статический анализ
- ☒ Динамическое тестирование
- ☒ Валидация контракта
- ☒ AI анализ

 Запустить анализ

Начало работы

VTB API 2025[→]
hackathon

<https://vtb.seag.pro/>

Расширение
проверок (по
предложениям
экспертов из жюри):

Пользовательские проверки:

Добавьте свои проверки, которые будут выполнены с помощью AI

+ Добавить проверку

Любые пользовательские проверки

Проверь уязвимость IDOR (Insecure Direct Object Reference): в endpoints для работы с продуктами (депозиты, кредиты, карты) может отсутствовать проверка владельца.



Включить проверку



Запустить анализ

Дождитесь результатов

VTB API 2025[→]
hackathon

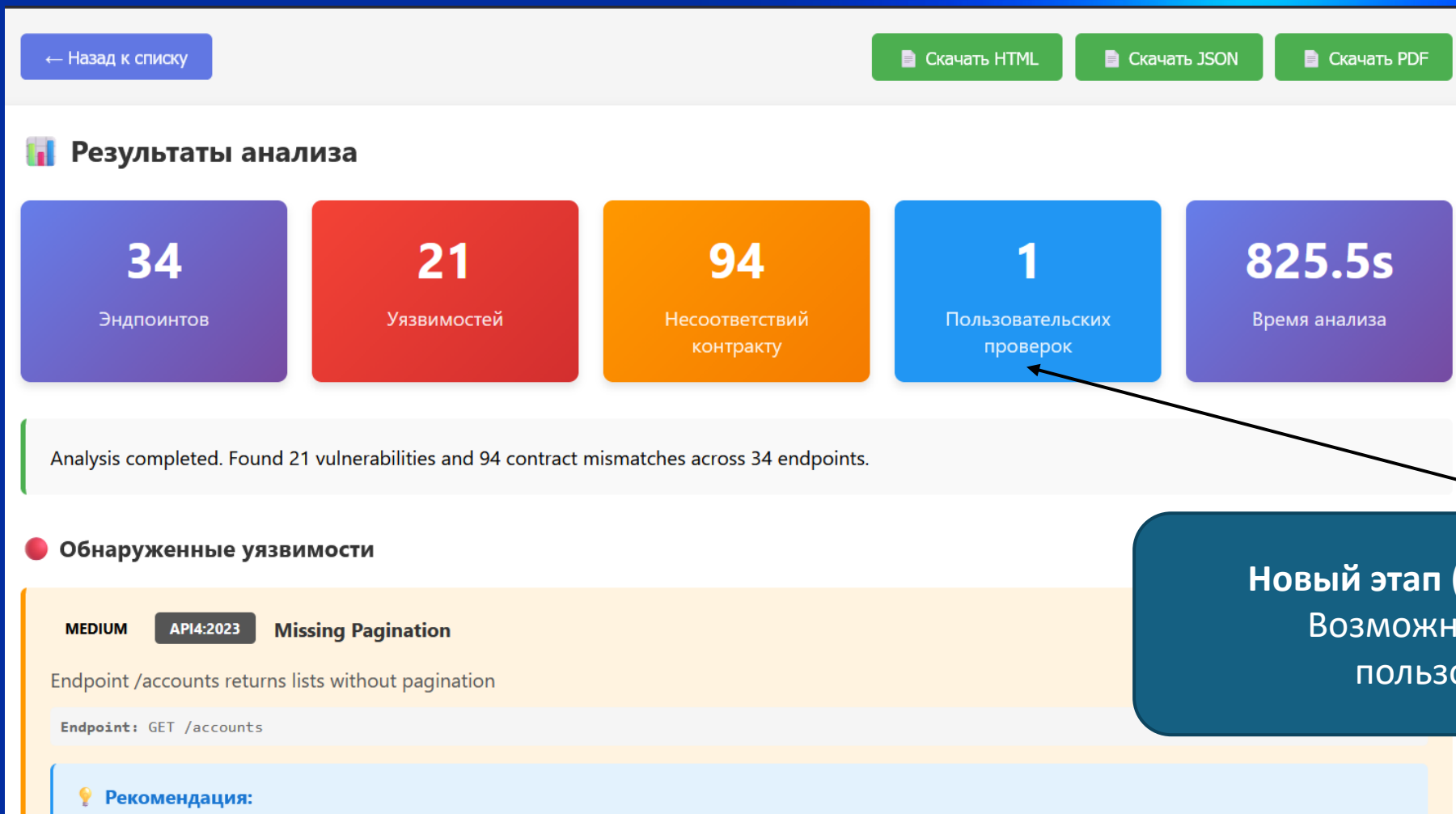
<https://vtb.seag.pro/>

Время начала	Банк	Описание	Статус	Длительность	Действия
09.11.2025, 12:53:48	VBank	VBank - Статический анализ, Динамическое тестирование, Валидация контракта, AI анализ	ВЫПОЛНЯЕТСЯ	1м 22с	<button>Остановить</button> 

Время начала	Банк	Описание	Статус	Длительность	Действия
09.11.2025, 12:53:48	VBank	VBank - Статический анализ, Динамическое тестирование, Валидация контракта, AI анализ	ЗАВЕРШЕН	6м 1с	Просмотр  HTML   JSON  PDF 

Изучите результаты

<https://vtb.seag.pro/>



Новый этап (по замечаниям экспертов):
Возможность расширения за счет
пользовательских проверок

Примеры уязвимостей

VTB API 2025[→]
hackathon

<https://vtb.seag.pro/>

HIGH

API8:2023

Cross-Site Scripting (XSS) Vulnerability

Parameter 'limit' in /accounts/{account_id}/transactions reflects user input without proper encoding

Endpoint: GET /accounts/{account_id}/transactions

Доказательство: XSS payload reflected in response

💡 Рекомендация:

Для устранения уязвимости XSS необходимо обеспечить правильное кодирование выходных данных (output encoding) при отображении пользовательского ввода. Параметр 'limit' должен быть строго валидирован на соответствие ожидаемому формату (например, положительное целое число), а любые данные, возвращаемые в ответе API, должны кодироваться в соответствии с контекстом использования (например, HTML, JavaScript, URL). Рекомендуется использовать проверенные библиотеки экранирования, такие как OWASP Java Encoder для Java или аналоги для других языков. Дополнительно следует реализовать Content Security Policy (CSP) на уровне HTTP-заголовков, чтобы минимизировать последствия возможных атак XSS.

Примеры уязвимостей

VTB API 2025[→]
hackathon

<https://vtb.seag.pro/>

HIGH

API4:2023

Missing Pagination

Endpoint /products returns lists without pagination

Endpoint: GET /products



Рекомендация:

Реализуйте пагинацию для эндпоинта /products, чтобы ограничить объем возвращаемых данных и предотвратить чрезмерное потребление ресурсов сервера и сети. Добавьте параметры, такие как 'page' и 'size' (или 'limit' и 'offset'), и установите разумные значения по умолчанию и максимальные лимиты (например, max limit = 100). Обеспечьте корректную обработку ошибок при невалидных параметрах. Также возвращайте метаданные пагинации (общее количество элементов, номер страницы, размер страницы) в ответе или заголовках, чтобы помочь клиентам эффективно навигировать по данным.

Примеры уязвимостей

VTB API 2025[→]
hackathon

<https://vtb.seag.pro/>

MEDIUM

API4:2023

No Rate Limiting Mentioned

Endpoint /payment-consents/request does not mention rate limiting in documentation

Endpoint: POST /payment-consents/request

💡 Рекомендация:

Реализуйте механизмы ограничения частоты запросов (rate limiting) для эндпоинта /payment-consents/request, чтобы предотвратить злоупотребления, такие как DoS-атаки, перебор или чрезмерное потребление ресурсов. Установите лимиты на количество запросов в единицу времени (например, 10 запросов в минуту на один IP-адрес или идентификатор пользователя). Убедитесь, что политики rate limiting документируются в спецификации API и применяются на уровне шлюза API или сервера приложений. Также предусмотрите обработку и логирование превышений лимитов для мониторинга подозрительной активности.

Примеры уязвимостей

<https://vtb.seag.pro/>

В контракте не упомянута возможность получения 429 статус-кода, как и наличие RateLimiter

⚠ Несоответствия контракту

Endpoint	Method	Type	Expected	Actual	Message
/accounts	GET	STATUS_CODE	200, 201, 400, 401, 403, 404, 500	429	Unexpected status code: 429
/cards	GET	STATUS_CODE	200, 201, 400, 401, 403, 404, 500	429	Unexpected status code: 429
/product-agreements	GET	STATUS_CODE	200, 201, 400, 401, 403, 404, 500	429	Unexpected status code: 429

Примеры уязвимостей

<https://vtb.seag.pro/>

Пользовательские проверки (новый этап):

 **Пользовательские проверки**

Дополнительная проверка ⚠️ ПРЕДУПРЕЖДЕНИЕ

Категория: Общая

Проверка на уязвимость IDOR (Insecure Direct Object Reference) в endpoints для работы с продуктами (депозиты, кредиты, карты) выявила потенциальные риски, связанные с отсутствием явной проверки принадлежности ресурсов клиенту. В представленной OpenAPI спецификации не хватает деталей реализации методов в тегах '5 Каталог продуктов', '7 Договоры с продуктами' и '8 Карты', включая параметры, заголовки и схемы ответов. Отсутствует описание механизма аутентификации и авторизации для этих endpoint'ов. В частности, неясно, как система проверяет, имеет ли запрашивающая сторона право доступа к конкретному продукту или договору. Поскольку в других разделах (например, /accounts) используется механизм согласий (consent) и заголовков (X-Consent-Id, X-Requesting-Bank), предполагается, что аналогичная логика должна применяться и к операциям с продуктами. Однако отсутствие явного описания этих механизмов в соответствующих endpoints создаёт неопределённость и потенциальную поверхность для атаки IDOR, особенно при межбанковом доступе. Рекомендуется дополнить спецификацию деталями проверки прав доступа на уровне ресурсов.

Найденные проблемы:

Потенциальная уязвимость к IDOR из-за отсутствия явной проверки владельца в endpoints продуктов

В спецификации отсутствует описание проверки принадлежности продукта (депозит, кредит, карта) клиенту при доступе к ресурсам. Не показано, как API обеспечивает, что только владелец или уполномоченная сторона может получить доступ к данным продукта. Это может привести к неправомерному доступу к данным других клиентов, если проверка реализована недостаточно строго.

Endpoint: GET /products

MEDIUM

Отсутствие детализации механизма согласий для управления продуктами

Для endpoints в тегах '7 Договоры с продуктами' и '8 Карты' не описано использование X-Consent-Id и X-Requesting-Bank, что необходимо для межбанковых операций. Это создаёт риск, что реализация может не проверять наличие действительного согласия перед выдачей данных или выполнением операций.

Endpoint: POST /contracts

MEDIUM

Выполнено: 21.11.2025, 10:32:46

Интеграция CI/CD

Пример - jenkins.seag.pro

Интеграция доступна через:

- Rest API
- ApiSecurityCli

ApiSecurityCli в стэйдже пайплайна вызывается через скрипт cli.sh (пример справа), в перспективе – разработка отдельного исполняемого CLI-инструмента на GoLang

Результат — проведенный поиск уязвимостей и ссылки на отчет

Что будет если перейти по ссылке из console output в Jenkins?

```

api-security-cli-pipeline / #24 / Console Output

+ chmod +x cli.sh
+ ./cli.sh --openapi-url https://vbank.open.bankingapi.ru/openapi.json --api-base-url https://vbank.open.bankingapi.ru --server-url https://vtb.seag.pro --enable-contract-validation --enable-ai-analysis
[Pipeline] echo
=====
API Security Analyzer CLI
=====

Отправка запроса на анализ...
URL: https://vtb.seag.pro/api/analysis/scan
OpenAPI URL: https://vbank.open.bankingapi.ru/openapi.json
API Base URL: https://vbank.open.bankingapi.ru

=====

Анализ завершен!
=====

Scan ID: b58ff909-a739-4393-8889-335976a315c2
Статус: RUNNING

=====

Ссылка на отчет:
https://vtb.seag.pro/api/reports/b58ff909-a739-4393-8889-335976a315c2/HTML

Ссылка на страницу отчета:
https://vtb.seag.pro/results/b58ff909-a739-4393-8889-335976a315c2
=====

```


Интеграция CI/CD

VTB API 2025
hackathon

Что доступно по ссылке из отчета в CI/CD ?

← Назад к списку

Скачать HTML

Скачать JSON

Скачать PDF

Результаты анализа

34
Эндпоинтов

2
Уязвимостей

0
Несоответствий контракту

241.4s
Время анализа

Analysis completed. Found 2 vulnerabilities and 0 contract mismatches across 34 endpoints.

Обнаруженные уязвимости

HIGH

API8:2023

Cross-Site Scripting (XSS) Vulnerability

Parameter 'limit' in /accounts/{account_id}/transactions reflects user input without proper encoding

Endpoint: GET /accounts/{account_id}/transactions

Доказательство: XSS payload reflected in response

Рекомендация:

Для устранения уязвимости XSS необходимо обеспечить правильное кодирование выходных данных (output encoding) в контексте, где они используются (например, HTML, JavaScript, URL). Параметр 'limit' должен быть строго экранирован на стороне сервера, принимая только безопасные значения.

Форматы отчетов

VTB API 2025
hackathon

<https://vtb.seag.pro/>

Поддерживаются форматы html,json,pdf.

Пример с PDF:

API Security Analysis Report

Summary

Scan ID: a3a93214-50ad-49c3-838e-1959392d9cb5

Status: COMPLETED

OpenAPI URL: https://vbank.open.bankingapi.ru/openapi.json

API Base URL: https://vbank.open.bankingapi.ru

Total Endpoints: 34

Total Vulnerabilities: 18

Contract Mismatches: 3

Summary: Analysis completed. Found 18 vulnerabilities and 3 contract mismatches across 34 endpoints.

Vulnerabilities

Заключение

<https://vtb.seag.pro>

- Решение универсально
- Результаты разных способов поиска уязвимостей агрегируются в один отчет
- Поддержка разных форматов отчетов – json/html/PDF
- Интеграция с CI/CD (на примере Jenkins) через RestAPI или CLI (пока скрипт->ApiSecurityCli.java, в перспективе — исполняемый файл, разработанный на GoLang)
- Результат анализа в CI/CD — ссылки на опубликованные отчеты
- **Новый этап — возможность расширения проверок пользовательскими**



Алексей Чайка

Капитан-разработчик

Спасибо за внимание!